

Dynamic Fee Sharing

Release 0.1.2

Smart Contract Security Assessment

July 2026

Prepared for:

Meteora

Prepared by:

Offside Labs

Sirius Xie





Contents

1	About Offside Labs	2
2	Executive Summary	3
3	Summary of Findings	5
4	Key Findings and Recommendations	6
4.1	Shareholders Can Clear Frozen Position Rewards	6
4.2	Incomplete Support for External Fee Claims	7
4.3	Missing Validation of Secondary Fee Destination	8
5	Disclaimer	10



1 About Offside Labs

Offside Labs is a leading security research team, composed of top talented hackers from both academia and industry.

We possess a wide range of expertise in modern software systems, including, but not limited to, *browsers, operating systems, IoT devices, and hypervisors*. We are also at the forefront of innovative areas like *cryptocurrencies* and *blockchain technologies*. Among our notable accomplishments are remote jailbreaks of devices such as the **iPhone** and **PlayStation 4**, and addressing critical vulnerabilities in the **Tron Network**.

Our team actively engages with and contributes to the security community. Having won and also co-organized *DEFCON CTF*, the most famous CTF competition in the Web2 era, we also triumphed in the **Paradigm CTF 2023** within the Web3 space. In addition, our efforts in responsibly disclosing numerous vulnerabilities to leading tech companies, such as *Apple, Google, and Microsoft*, have protected digital assets valued at over **\$300 million**.

In the transition towards Web3, Offside Labs has achieved remarkable success. We have earned over **\$9 million** in bug bounties, and **three** of our innovative techniques were recognized among the **top 10 blockchain hacking techniques of 2022** by the Web3 security community.



<https://offside.io/>



<https://github.com/offsidelabs>



https://twitter.com/offside_labs



2 Executive Summary

Introduction

Offside Labs completed a security audit of *Dynamic Fee Sharing* smart contracts, starting on May 18th, 2026, and concluding on July 21th, 2026.

Project Overview

Dynamic Fee Sharing Release 0.1.2 provides token fee distribution among two to five recipients according to fixed shares. It supports independently created and program derived fee vaults, direct deposits, and restricted fee collection from Meteora DAMM v2 positions and Dynamic Bonding Curve creator and partner roles. Accrued amounts are tracked per share and can be claimed independently using standard SPL tokens or selected Token 2022 mints. The release also upgrades the Anchor framework to version 1.0.2.

Audit Scope

The assessment scope contains mainly the smart contracts of the dynamic-fee-sharing program for the *Dynamic Fee Sharing* project.

The audit is based on the following specific branches and commit hashes of the codebase repositories:

- Dynamic Fee Sharing
 - Codebase: <https://github.com/MeteoraAg/dynamic-fee-sharing>
 - Release 0.1.2: [PR-15](#)
 - Commit Hash: 31aa0734255ac6884fa0c29ba186158a1214e15a

The issues described in this report have been resolved by the following commit:

- Dynamic Fee Sharing
 - Codebase: <https://github.com/MeteoraAg/dynamic-fee-sharing>
 - Commit Hash: 1707ff04ebb310ffa1225cd9241424ba3287b650

We listed the files we have audited below:

- Dynamic Fee Sharing Release 0.1.2
 - programs/dynamic-fee-sharing/src/instructions/ix_initialize_fee_vault_pda.rs
 - programs/dynamic-fee-sharing/src/instructions/mod.rs
 - programs/dynamic-fee-sharing/src/instructions/ix_claim_fee.rs
 - programs/dynamic-fee-sharing/src/instructions/ix_fund_fee.rs
 - programs/dynamic-fee-sharing/src/instructions/ix_initialize_fee_vault.rs
 - programs/dynamic-fee-sharing/src/instructions/ix_fund_by_claiming_fee.rs
 - programs/dynamic-fee-sharing/src/constants.rs
 - programs/dynamic-fee-sharing/src/error.rs
 - programs/dynamic-fee-sharing/src/const_pda.rs
 - programs/dynamic-fee-sharing/src/lib.rs



- programs/dynamic-fee-sharing/src/utils/token.rs
- programs/dynamic-fee-sharing/src/utils/mod.rs
- programs/dynamic-fee-sharing/src/event.rs
- programs/dynamic-fee-sharing/src/state/fee_vault.rs
- programs/dynamic-fee-sharing/src/state/mod.rs
- programs/dynamic-fee-sharing/src/math/math_utils.rs
- programs/dynamic-fee-sharing/src/math/mod.rs
- programs/dynamic-fee-sharing/src/math/safe_math.rs
- programs/dynamic-fee-sharing/src/macros.rs

Findings

The security audit revealed:

- 0 critical issue
- 0 high issue
- 0 medium issue
- 3 low issues
- 0 informational issue

Further details, including the nature of these issues and recommendations for their remediation, are detailed in the subsequent sections of this report.



3 Summary of Findings

ID	Title	Severity	Status
01	Shareholders Can Clear Frozen Position Rewards	Low	Fixed
02	Incomplete Support for External Fee Claims	Low	Fixed
03	Missing Validation of Secondary Fee Destination	Low	Acknowledged



4 Key Findings and Recommendations

4.1 Shareholders Can Clear Frozen Position Rewards

Severity: Low

Status: Fixed

Target: Smart Contract

Category: Data Validation

Description

DFS validates the DAMM v2 ClaimReward discriminator and reward destination account but forwards the caller-provided instruction payload without checking `skip_reward`. When the reward vault is frozen and `skip_reward` equals 1, DAMM v2 records the pending reward as claimed but does not transfer it:

```
109     let total_reward = position.claim_reward(index)?;
110
111     // transfer rewards to user
112     if total_reward > 0 {
113         if ctx.accounts.reward_vault.is_frozen() {
114             require!(skip_reward == 1,
115                 => PoolError::RewardVaultFrozenSkipRequired)
116         } else {
```

[programs/cp-amm/src/instructions/ix_claim_reward.rs#L109-L117](#)

The called `claim_reward` function resets the position's pending reward balance:

```
336     pub fn claim_reward(&mut self, reward_index: usize) -> Result<u64> {
337         let total_reward = self.get_total_reward(reward_index)?;
338
339         self.accumulate_total_claimed_rewards(reward_index, total_reward);
340
341         self.reset_all_pending_reward(reward_index);
342
343         Ok(total_reward)
344     }
```

[programs/cp-amm/src/state/position.rs#L336-L344](#)

Because any shareholder can initiate the DFS claim and DFS signs as the owner of the position NFT account, any shareholder can clear pending rewards for a frozen reward vault without funding the FeeVault.

Impact

Pending rewards for the selected reward index are removed from the position's claimable balance without being distributed to the FeeVault shareholders.



Recommendation

It is recommended to deserialize the DAMM V2 ClaimReward arguments in `handle_fund_by_claiming_fee` and reject calls where `skip_reward` is not zero.

Mitigation Review Log

Fixed in the commit 486bdb3fb5642e07c93a5003fc3ee2012371833d.

4.2 Incomplete Support for External Fee Claims

Severity: Low

Status: Fixed

Target: Smart Contract

Category: Design

Description

DFS allows the FeeVault PDA to sign an external CPI only when the instruction appears in `WHITELISTED_ACTIONS`. Any omitted instruction is rejected:

The whitelist does not support the following fee-claiming instructions:

- `DBC ClaimTradingFee2` : Allows the configured partner fee claimer to claim partner trading fees from a `TransferHookPool` . The whitelisted `ClaimTradingFee` instruction supports only a `regular VirtualPool` . If the FeeVault is the configured fee claimer of a transfer-hook pool, its partner trading fees cannot be claimed through DFS.
- `DBC ClaimCreatorTradingFee2` : Allows the pool creator to claim creator trading fees from a `TransferHookPool` . The whitelisted `ClaimCreatorTradingFee` instruction supports only a `regular VirtualPool` . If the FeeVault is the creator of a transfer-hook pool, its creator trading fees cannot be claimed through DFS.
- `DBC ClaimPartnerPoolCreationFee` : Allows the configured partner fee claimer to collect the partner portion of a pool-creation fee in lamports. If the FeeVault is the configured fee claimer, it cannot provide the required PDA signature outside DFS, while DFS does not expose a path to execute this claim. The partner's pool-creation fee consequently remains unclaimed in the pool.
- `DAMM v1 ClaimFee` : Allows a lock escrow owner to claim fees accrued by locked LP tokens as the pool's token A and token B. If a DBC pool migrates to DAMM v1 and the FeeVault owns a partner or creator lock escrow, it cannot provide the required PDA signature outside DFS, while DFS does not expose a path to execute this claim. The locked LP fees consequently remain unclaimed.

Impact

Depending on the external pool type and the role assigned to the FeeVault, partner trading fees, creator trading fees or partner pool-creation fees cannot be claimed or distributed to



FeeVault shareholders.

Recommendation

It is recommended to add explicit DFS claim paths for each omitted instruction.

- The TransferHook trading-fee paths should validate their token destinations,
- The pool-creation-fee path should account for received lamports,
- The DAMM v1 locked LP fee path should explicitly handle and account for both token outputs.

Mitigation Review Log

Meteora Team:

- `DBC ClaimCreatorTradingFee2` & `DBC ClaimTradingFee2` : Fixed in commit `356a73e9b22f4f678475275cefe1f93983320e93`.
- `DBC ClaimPartnerPoolCreationFee` : Currently unsupported. Supporting it would require additional handling to wrap the claimed native SOL.
- `DAMM v1` : Not supported due to a lack of demand and DAMM v1 is a legacy program.

4.3 Missing Validation of Secondary Fee Destination

Severity: Low

Status: Acknowledged

Target: Smart Contract

Category: Data Validation

Description

In `fund_by_claiming_fee`, any FeeVault shareholder can invoke a whitelisted external claim. For each action, DFS validates only the account at one configured token vault index:

```
31     if program.eq(source_program) && disc.eq(discriminator) {
32         if let Some(token_vault_account) =
33             remaining_accounts.get(token_vault_index) {
34             return token_vault.eq(token_vault_account.key);
35         }
36     }
```

[programs/dynamic-fee-sharing/src/instructions/ix_fund_by_claiming_fee.rs#L31-L36](#)

DFS forwards the remaining accounts and instruction payload without validating any other output destination. After the CPI, it records only the balance increase of the validated token vault.



For DAMM v2 `ClaimPositionFee` , DFS validates `token_b_account` . However, a `BothToken` position can contain pending fees in both token A and token B. DAMM v2 transfers both amounts to the caller-provided accounts before resetting them. When the FeeVault owns the position NFT account, DAMM v2 accepts the FeeVault signature without validating either destination.

Consequently, a shareholder can provide the FeeVault token vault as `token_b_account` while providing an account they control as `token_a_account` .

The same issue affects DBC trading fee claims. DFS validates only the quote token destination for `ClaimTradingFee*` and `ClaimCreatorTradingFee*` IXs while the DBC instructions accept separate base token and quote token destinations. Under `OutputToken` collection mode, fees can accrue in either token depending on the trade direction.

The partner and creator claim instructions deduct the requested base and quote fees and transfer them to the respective caller-provided accounts. Therefore, when the FeeVault is the partner fee claimer or creator, a shareholder can direct the base token fees to their own account while routing only the quote token fees into the FeeVault.

Impact

For a DAMM v2 `BothToken` position or a DBC `OutputToken` pool, any FeeVault shareholder can redirect all pending token A or base token fees to an account they control. Only token B or quote token fees are recorded and distributed to the other shareholders.

Recommendation

It is recommended to validate the external pool's collection mode before executing the claim. DFS should reject DAMM v2 `BothToken` position fee claims and DBC `OutputToken` trading fee claims, and require the DBC `max_base_amount` argument to be zero.

Mitigation Review Log

Meteora Team: This is intended design: DFS is intentionally designed and documented to support only single-sided fee pools for DAMM v2 and DBC. Each FeeVault supports one token mint and one token vault, so dual-output claim scenarios are not supported.

Add some comments in the commit 1707ff04ebb310ffa1225cd9241424ba3287b650.



5 Disclaimer

This audit report is provided for informational purposes only and is not intended to be used as investment advice. While we strive to thoroughly review and analyze the smart contracts in question, we must clarify that our services do not encompass an exhaustive security examination. Our audit aims to identify potential security vulnerabilities to the best of our ability, but it does not serve as a guarantee that the smart contracts are completely free from security risks.

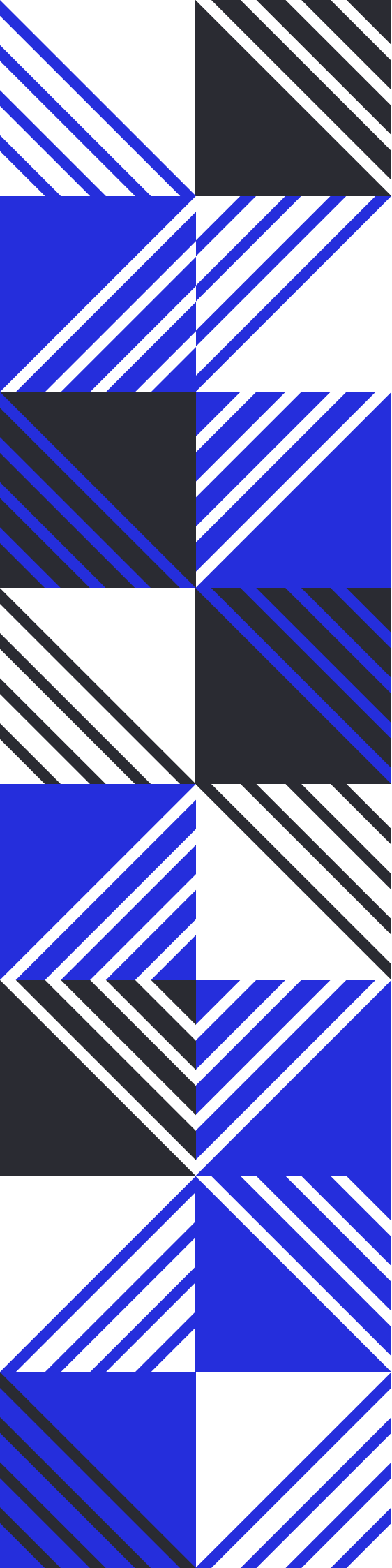
We expressly disclaim any liability for any losses or damages arising from the use of this report or from any security breaches that may occur in the future. We also recommend that our clients engage in multiple independent audits and establish a public bug bounty program as additional measures to bolster the security of their smart contracts.

It is important to note that the scope of our audit is limited to the areas outlined within our engagement and does not include every possible risk or vulnerability. Continuous security practices, including regular audits and monitoring, are essential for maintaining the security of smart contracts over time.

Please note: we are not liable for any security issues stemming from developer errors or misconfigurations at the time of contract deployment; we do not assume responsibility for any centralized governance risks within the project; we are not accountable for any impact on the project's security or availability due to significant damage to the underlying blockchain infrastructure.

By using this report, the client acknowledges the inherent limitations of the audit process and agrees that our firm shall not be held liable for any incidents that may occur subsequent to our engagement.

This report is considered null and void if the report (or any portion thereof) is altered in any manner.



 <https://offside.io/>

 <https://github.com/offsidelabs>

 https://twitter.com/offside_labs